Studio Nx

AI 구현 설명 17 — 로그인 · 토큰 재발급 · 로그아웃 템플릿

2026-10-18

AI 구현 설명 17 — 로그인 · 토큰 재발급 · 로그아웃 템플릿

항목	내용
작성	Claude (AI)
작성일	2026-10-03
작업	P1-05 로그인(JWT), 리프레시 쿠키, 재발급, 로그아웃, `last_login_at` (**템플릿**), 이전 문서: 16_signup_api_template.md
브랜치	`feature/phase1/p1-05-login-jwt` (P1-04 브랜치에서 갈라졌으므로 **P1-04 PR을 먼저 병합**해야 합니다)
원칙	백엔드는 **템플릿만** 만들었습니다 (라우터, 스키마, 함수 이름과 TODO). 실제 구현은 사용자가 합니다

---

1. 무엇을 만들었나

파일	상태	내용
`app/api/v1/auth.py`	템플릿 추가	`POST /auth/login`, `POST /auth/refresh`, `POST /auth/logout`과 쿠키 함수 `set_refresh_cookie`, `clear_refresh_cookie`를 추가했습니다
`app/schemas/auth.py`	완성해서 추가	`LoginRequest {email, password, remember}`와 `TokenResponse {access_token, token_type, expires_in}` 입니다
`app/services/auth_service.py`	템플릿 추가	`authenticate`(로그인 확인과 `last_login_at` 기록)와 `get_active_user`(재발급용 계정 확인)입니다
`app/core/security.py`	템플릿 추가	`decode_refresh_token` 입니다 (기존의 `verify_password`, `create_*_token` TODO도 이번 작업에서 채웁니다)
`tests/test_auth_routes.py`	완성해서 추가	세 주소의 연결을 확인합니다

2. 왜 이렇게 했나

2.1 토큰 흐름

```
로그인 모달 ──POST /auth/login {email, password, remember}──▶ 서버
          ◀── 200 {access_token}  +  Set-Cookie: snx_refresh (HttpOnly)
페이지 이동 ──POST /auth/refresh (쿠키 자동 첨부)──▶ 서버
          ◀── 200 {access_token}   또는 401 (비로그인)
API 요청   ──Authorization: Bearer <access_token>──▶ get_current_user
로그아웃   ──POST /auth/logout──▶ 쿠키 삭제 (204)
```

토큰	보관	기간
Access Token	화면 메모리 (`api.js`의 변수)	30분
Refresh Token	HttpOnly 쿠키 `snx_refresh`	토큰은 3일입니다. 쿠키는 자동 로그인을 체크하면 3일, 아니면 세션 쿠키입니다

2.2 쿠키 설정

옵션	값	이유
`httponly`	`True`	JS에서 읽을 수 없습니다 (XSS로 토큰을 훔치지 못합니다)
`samesite`	`lax`	다른 사이트에서 보낸 POST에는 실리지 않습니다 (CSRF 대비)
`secure`	배포(`prod`)에서만 켭니다	개발 서버는 HTTP라서 켜면 쿠키가 저장되지 않습니다
`path`	`/api/v1/auth`	쿠키가 인증 요청에만 실립니다
`max_age`	자동 로그인을 체크하면 3일이고, 아니면 없습니다	FR-109

2.3 로그인 실패 응답

경우	응답
이메일이 없음, 비밀번호가 틀림, 탈퇴(`DELETED`)	401 `INVALID_CREDENTIALS` "Email or password is incorrect."로, 모두 같은 문구입니다
정지(`SUSPENDED`)	403 `ACCOUNT_DISABLED`

탈퇴한 계정도 같은 문구로 돌려주므로, 그 이메일로 가입한 적이 있는지 알 수 없습니다.

2.4 정한 것과 바꾼 것

항목	내용
리프레시 토큰 저장	DB에 저장하지 않습니다 (테이블 없음). 서명과 만료만 검사합니다
탈퇴한 뒤 남은 쿠키	`/auth/refresh`에서 `get_active_user`로 계정 상태를 다시 확인하고 401로 응답합니다
로그아웃 인증	PRD 01 §7의 표는 인증 ✓이지만, Access Token이 만료된 상태에서도 쿠키는 지워져야 합니다. 그래서 **로그인 확인 없이** 받도록 템플릿에 적었습니다 (쿠키만 지우므로 위험하지 않습니다)

> 리프레시 토큰을 DB에 두지 않으면 "다른 기기 모두 로그아웃"은 할 수 없습니다. 필요해지면 `refresh_tokens` 테이블을 DB.md에 추가하는 방식으로 넓힙니다.

3. 검증 결과 (2026-10-03)

확인	결과
`pytest`	8개가 통과했습니다
`ruff check`	통과했습니다
OpenAPI	`/auth/login`, `/auth/refresh`(쿠키 `snx_refresh`), `/auth/logout`이 표시됩니다

4. 남은 일 (사용자)

순서	할 일	파일
1	`verify_password`, `create_access_token`, `create_refresh_token`, `decode_*_token`	`app/core/security.py`

순서	할 일	파일
2	`authenticate`, `get_active_user`	`app/services/auth_service.py`
3	쿠키 함수 2개, 라우터 3개	`app/api/v1/auth.py`
4	화면 연결	`core/api.js`의 `refreshAccessToken`, `core/auth-ui.js`의 `initLoginForm`, `core/auth.js`의 로그아웃 (P1-07)

5. 자주 받을 질문 대비

- **Q. Access Token을 왜 localStorage에 두지 않나요?** 페이지에 악성 스크립트가 들어오면 localStorage는 그대로 읽힙니다. 메모리에 두고, 페이지를 옮기면 HttpOnly 쿠키로 다시 받습니다.
- **Q. 로그인하지 않은 상태에서 페이지마다 401이 뜨는데 괜찮나요?** 정상적인 흐름입니다. 화면은 401을 "로그인하지 않음"으로 처리하고 헤더를 Sign In / Join Us로 둡니다.
- **Q. 자동 로그인을 하지 않았는데 토큰이 3일짜리인 이유는 무엇인가요?** 토큰 만료와 쿠키 수명은 따로입니다. 세션 쿠키라서 브라우저를 닫으면 토큰도 함께 사라집니다.
- **Q. `Cookie(alias=...)`는 왜 쓰나요?** 쿠키 이름(`snx_refresh`)과 파이썬 매개변수 이름(`refresh_token`)을 다르게 쓰기 위해서입니다.